

DPIA — Chat-Corpus Research (LLM proxy survey responses)

0. Why a DPIA

Processing involves (i) special-category data likely present in private messages (Art. 35(3)(b)), (ii) novel technical means (LLM retrieval pipeline, Art. 35(1)), (iii) data subjects who cannot self-assert rights (OTHERs not individually notified). DPIA therefore required. DPO consultation under Art. 35(2) is undertaken with this review [TODO 2026-09-29]; comments and our responses logged in §7. Consultation ≠ approval (Art. 38(3)).

1. Processing description (Art. 35(7)(a))

Purpose. Scientific research (university controllership): measure whether an LLM with retrieval over a donor’s own chat corpus can reproduce that donor’s survey responses (fidelity of stimulus→reaction imitation). Specific surveys/stimuli TBD by the research protocol. No other use.

Research qualification (DBL §10). §10 requires that the processing be solely for scientific research of significant societal importance (*væsentlig samfundsmæssig betydning*) and necessary to it. The project extends a funded research line (Daniel Hardt; peer-reviewed abstract “LLMs as Proxy Survey Participants With RAG”, Torjani, Brikas & Hardt, SLTC 2024), targeting individual-level LLM behavioural imitation, an open research frontier. The authentic corpus is the necessary input; no equal-validity substitute exists. The processing is solely research; §10(2) bars any other later use.

Controller. Copenhagen Business School (CBS). Project responsible: Daniel Hardt. Named access: Elias Torjani, Airidas Brikas (students) + Daniel Hardt (supervisor), no one else. The project sits under CBS; Brikas (DTU) and Torjani (CBS) process solely as authorised persons under CBS’s mandate. Controller status follows Datatilsynet’s role guidance (Rollefordeling i forskningsprojekter, Jul 2023, §3.1.7): the project is a subproject of the supervisor’s research line; the university determines purpose and essential means and is named as controller in the Art. 30 record.

Data. Donor-selected chat exports (FB/IG/WhatsApp text), transcribed audio (raw audio deleted at ingestion), survey responses, consent record, contact email. No images or video. No CPR collected; no targeted collection of criminal-offence data.

Data subjects. (1) Donors (“SUBJECT”) — adults, informed consent (Art. 6(1)(a), 9(2)(a)). (2) Chat partners (“OTHER”) — their messages appear in donor exports. (3) Persons mentioned in messages. Categories 2–3 are never analyzed, profiled, or quoted; their messages serve only as conversational context for imitating the SUBJECT.

Legal basis. Art. 6(1)(e) (public-interest task) + Art. 9(2)(j) with DBL §10. §10(1) permits processing of special categories without consent where the processing is solely for scientific research of significant societal importance and necessary to it; §10(2) restricts the data to scientific/statistical use throughout. Art. 14(5)(b) exempts individual notice to OTHERs/mentioned (no contact channel exists; donor-mediated notice is infeasible at 10^2 – 10^3 contacts per donor and would impair the research objective — recruitment friction documented). No personal data is disclosed; only

non-identifiable aggregates are published or shared, so §10(3) authorisation is not triggered. Under DBL §22(5), Arts. 15/16/18/21 do not apply to exclusively-research processing; as a safeguard we voluntarily honor erasure/objection at any time via the project mailbox → deletion. Safeguards per Art. 89(1): below.

Flow. Donor upload (consent + T&C) → encrypted uCloud storage (DeiC, EU; Art. 28 DPA) → header pseudonymization (names → SUBJECT/OTHER) → retrieval-based inference, no model training on personal data → aggregate fidelity metrics only. No raw corpus publication, no quotes, no commercial/demo use.

Retention. Corpus incl. backups destroyed by 29 February 2027 (thesis assessment deadline); same date fixed in the Art. 30 record + T&C. Only non-identifiable aggregates retained.

2. Necessity & proportionality (Art. 35(7)(b))

Imitation validity requires authentic, unedited conversational data; removing OTHERs' messages or altering content changes register/lexicon and invalidates the measurement. OTHERs are never the unit of analysis — their messages serve only as retrieval context for imitating the SUBJECT, and no profiling, quotes, or per-individual results are produced. Consent-all is infeasible (no channel) and self-defeating (selection bias, recruitment collapse). Processing is confined to the stated research purpose; destruction on schedule. On balance: research benefit vs. minimal per-person impact (use-limited, transient) → proportionate.

3. Data subject rights

Donors: full Art. 12–22 channel via T&C + mailbox (withdrawal → full deletion). OTHERs/mentioned: no individual channel exists (Art. 14(5)(b) exempts notice); under DBL §22(5), Arts. 15/16/18/21 are derogated for exclusively-research processing — notwithstanding, as a safeguard we honor erasure/objection requests whenever raised via the project mailbox (locate via donor-side key → delete → written confirmation). No pre-processing window. Art. 22: no automated decisions about any person.

4. Risk assessment (Art. 35(7)(c))

Method: “Likelihood” and “Severity” are **inherent** (before safeguards). “Residual” = remaining risk **after** the §5 safeguards. Scale: Very low < Low < Medium < High < Very high. Each residual traces to its mitigations in §5.

#	Risk	Likelihood	Severity	Residual after §5
R1	Unauthorized access to corpus	Low	High	Low
R2	Re-identification of OTHERs via outputs	Very low	High	Very low (aggregates only, no quotes)
R3	Misuse beyond research purpose	Low	Medium	Very low (no external APIs, no training, research-only commitment, aggregate-only outputs)
R4	OTHERs unaware → no ex-ante objection	Objection window foreclosed by design	Low	Low (erasure honored anytime) – the documented 14(5)(b) trade
R5	Retention overrun	Low	Medium	Very low (automated destruction incl. backups + written confirmation)
R6	Insider misuse (named project members only)	Very low	High	Very low (small named team, MFA, logging, no exfil path)

5. Safeguards (Art. 89(1), 32)

Header pseudonymization (SUBJECT/OTHER) at ingestion; encryption at rest/in transit; access restricted to named project members via university login (MFA); uCloud/DeiC processor, EU-only, no sub-processors outside EU; no external APIs receive personal data; audio transcribed locally on uCloud with raw audio deleted at ingestion, no images/video retained; retrieval-only (no training on personal data); aggregate-only publication; no disclosure of personal data (§10(3) not triggered); transparency substitute: donor T&C + erasure mailbox; destruction schedule incl. backups with written confirmation; breach handling per Art. 33/34 (OTHERs unreachable individually; relayed via donors where feasible, documented).

6. Residual risk & Art. 36

Residual risks $\leq$ Low. No unmitigable high risk $\rightarrow$ no prior consultation with Datatilsynet.
Reassess if DPO consultation identifies risks we cannot mitigate.

7. Consultation & review

Party	Record
DPO – prior round	[TODO: dates of email correspondence]: advice = consent-or-anonymise; premised on student-controllership (now corrected) $\rightarrow$ superseded by revised basis
DPO (Art. 35(2))	Re-consulted on revised basis [TODO 2026-09-29]; comments and our responses logged here
Data subjects (Art. 35(9))	Donors via consent flow; OTHERs not individually contactable (documented) – rights route per §3
Review trigger	Change of purpose, access roster, processor, retention; else annually while data held

8. Sign-off

Role	Name	Date
Project responsible (controller side)	[]	
DPIA authors (students)	[] []	
DPO consultation logged	[]	